

Artificial Intelligence (AI) Security Procedure

**Standard Operating Procedure: Artificial Intelligence Procedure****Procedure for Artificial Intelligence (AI) Security**

Version	1.0
Effective Date	22-12-2025
Compiled by	Saurabh Kumar
Reviewed by	Ratnesh Singh
Approved by	CISO

Revision and Version Control:

Version	Date	Reason for Revision/Update	Created/Updated By	Reviewed By	Approved By
1.0	22-12-25	First Draft	Saurabh Kumar	Ratnesh Singh	CISO

Sign-Off Matrix:

Name	Designation	Sign-Off	Date
Salil Harjarnis	CTO	Received	20-12-2025
Harsh Kumar	Head- Artificial Intelligence	Received	24-12-2025
Pawan Lakhotia	Senior Compliance Officer	Received	24-12-2025
Gaurav Sharma	Head- Operational Risk	Received	24-12-2025

**Standard Operating Procedure: Artificial Intelligence Procedure**

Contents

1. Purpose	4
2. Scope	4
3. Definition.....	4
4. Roles and Responsibilities	4
5. AI Security Guidelines for End-users.....	5
6. AI Security Guidelines for Developers.....	5
7. AI Security Guidelines for Business process enhancement or automation	6
8. Access Control.....	6
9. Security Assessment and Vulnerability Management.....	6
10. Data Privacy	6
11. Data Localization	6
12. Third Party Risks	6
13. Monitoring and Logging.....	7
14. Incident Reporting and Management.....	7
15. Business Continuity Management	7
16. Awareness	7
17. Exception	7
18. Review and Updates	7



Standard Operating Procedure: Artificial Intelligence Procedure

1. Purpose

This SOP provides detailed operational procedures to implement AI Security. It ensures secure use, development, and integration of AI technologies while maintaining confidentiality, integrity, availability, privacy and regulatory compliance.

2. Scope

This SOP applies to:

- All on-roll and off-roll employees using AI tools/systems
- Development teams using AI for coding, testing, or deployment
- Business units leveraging AI for process enhancement or automation

3. Definition

PFL	Poonawalla Fincorp Limited
CTO	Chief Technology Officer
CISO	Chief Information Security Officer
Infosec	Information Security
IT	Information Technology
Artificial intelligence (AI)	Systems or machines that mimic human intelligence to perform tasks and can iteratively improve themselves based on the information they collect
MIS	Management Information System
BRD	Business Requirement Document
HOD	Head of Department
DPDP	Digital Personal Data Protection
PSD	Poonawalla Service Desk
BIA	Business Impact Assessment
BCP-DR	Business continuity Process – Disaster Recovery
SOC	Security Operation Center

4. Roles and Responsibilities

Role	Responsibility
AI System Owner or AI Head	Ensure AI systems comply with security and regulatory requirements & provide inventory of all AI solutions, tools built by AI team.
Information Security Team	Governance of AI security controls
IT Team	Implement technical safeguards, access controls and maintain an updated inventory of AI solutions/tools deployed through IT and Infosec
Business Unit Heads (BUH)	When the business adopts or onboards any AI-enabled application/ Gen AI tools, the BUH must ensure compliance with the organization's AI Security Procedures, and coordinate

Standard Operating Procedure: Artificial Intelligence Procedure

	with the IT & Information Security team for necessary validations before deployment.
Employees/Users	Use AI system/tool responsibly and report incident
L&D Team	Employee Awareness for AI Security

5. AI Security Guidelines for End-users

Ensure responsible and secure use of AI system/tool by all employees (using Gen AI solution).

- Employees must use only approved AI systems.
- Do not input or share sensitive data over AI system/tool such as:
 - ✓ Credentials
 - ✓ Internal IP addresses
 - ✓ Company documents (Policies, SOP, Audit report, MIS, BRD, Approach document etc.)
 - ✓ Documents containing sensitive information that may, either directly or indirectly, reveal an association with PFL
 - ✓ Employment details
 - ✓ Privileged communications
 - ✓ Customer data
 - ✓ Personally Identifiable Information (e.g., Aadhaar, PAN, bank statement)
 - ✓ Financial or regulatory-sensitive data
 - ✓ Intellectual property data
 - ✓ Audit reports
- Avoid using AI system/tools to generate or reuse content that may infringe on copyrights or proprietary materials.
- Do not upload confidential files (e.g., audit reports, presentations, MIS) unless explicitly approved. Responsibility for uploaded content lies with the user/ department.
- Do not use AI systems to store or archive sensitive information.
- Avoid using AI for generating misleading, biased, or discriminatory content.
- Respect intellectual property and copyright laws when using AI-generated outputs.
- Ensure compliance against internal data leakage and classification policies.
- Report any misuse or anomalies to the Information Security Team immediately (Infosec@poonawallfincorp.com) or in PSD tool

6. AI Security Guidelines for Developers

Ensure secure and ethical integration of AI in software development lifecycles.

- Follow secure software development lifecycle (S-SDLC) principles when using AI-assisted coding tools or codes generated by AI tools. (for more details refer SDLC SOP)
- All AI-generated code must undergo review including static code review using tools (SAST).
- Developers must verify, document, and validate AI-generated code.
- Developers remain accountable for all code submitted to production and to ensure that code remains free from subtle logic errors.
- Developers should ensure that there are no conflicts of license/ ownership of intellectual property of AI-generated code and avoid using AI system/tools that replicate copyrighted or proprietary code. This can be done through review with compliance, legal and procurement team before using any tools.

**Standard Operating Procedure: Artificial Intelligence Procedure****7. AI Security Guidelines for Business process enhancement or automation**

Below guidelines are applicable to all AI models deployed across business units, internal and third-party AI solutions and cloud, on-premises, and hybrid environments.

Ensure responsible adoption of AI in business operations with transparency and oversight.

- All AI use cases must be reviewed and approved by respective HOD / nominated individuals.
- Maintain documentation of AI logic, data sources, and decision-making processes.
- Enable audit trails for all AI-driven processes.
- Ensure due diligence is conducted on external AI service providers and system/tools. (for more details refer to Infosec Vendor Due diligence SOP)
- Any changes to AI systems must follow PFL change management process.
- Maintain version control and rollback mechanisms.
- Ensure the LLM models which are deployed in PFL managed environment are not directly / indirectly expose to internet, which are using the customer, organization or critical data for learning and training purposes.
- Segregation of environment must be ensured into testing and production environments.

8. Access Control

- Role-based access must be enforced for AI systems
- Multi-factor authentication (MFA) should be enabled where applicable
- Planned user access review as per the current IT guideline must be followed. Currently this is quarterly.

9. Security Assessment and Vulnerability Management

- Information security assessments shall be done during testing, pre-deployment phase as well as periodically, even after AI tools have been deployed.
- The due diligence shall include all checks as per PFL standard due diligence assessment process, additionally AI related risks should also be assessed.
- Vulnerabilities related to AI systems shall be tested as per PFL vulnerability assessment process.

10. Data Privacy

- Sensitive data like PII (Name, Aadhaar, PAN etc.) shall be anonymized to avoid unauthorized data disclosure in case of data breach or cyber incident.
- Methods such as masking, pseudonymization or aggregation shall be used for anonymization.
- Ensure customer consent is in place while using/ extracting customer data as per applicable legislation such as DPDP act.

11. Data Localization

All testing/ experimental, pre-production and production data used in AI tools and AI model training should reside in the geographical boundary of India.

12. Third Party Risks

- Since AI implementations often rely on external vendors, cloud service providers, and technology partners to supply, maintain, and/or operate AI systems, they can expose PFL to risks such as software defects, non-compliance with regulatory obligations, breaches of contractual terms etc.

**Standard Operating Procedure: Artificial Intelligence Procedure**

- Due diligence and risk assessments shall be conducted during boarding as well as periodically to verify service provider's security controls and ensure compliance with regulatory guidelines.
- For SaaS based AI System, if any, service providers should have adopted the control or best practices such as ISO 42001 or equivalent.

13. Monitoring and Logging

- All AI interactions must be logged
- Logs should be retained as per policy.

14. Incident Reporting and Management

- Incidents related to AI systems can result in significant financial, operational, or reputational loss, such incidents must be reported to Information security team immediately.
- All such incidents shall be addressed as per PFL incident management processes.

15. Business Continuity Management

- Identification of Criticality of AI systems shall be done as per PFL BIA process.
- Upon identification, BCP/ DR requirements for all critical AI systems which are being used for critical processes shall be governed by PFL BCM policy, if applicable.
- BCP/DR drills and simulations drills for all such AI systems shall be conducted as per BCP-DR requirement if applicable and as per applicable regulatory guidelines.
- For SaaS based AI System, the obligation of performing BCP/DR drill lies with respective service provider.
- In case, where service provider is not contractually obliged to perform drills as per PFL guidelines, Service provider's SOC -II report or equivalent shall be obtained by respective business units.

16. Awareness

- Awareness for all employees on secure AI usage should be done periodically by the L&D team.
- Consultation of Infosec team shall be done for awareness related content.

17. Exception

Any exception to this procedure shall require mandatory approval from AI Head, CTO and CISO.

18. Review and Updates

This SOP will be reviewed annually or upon significant changes in AI security or regulations.